

Experiment 4: Social Engineering attack (SEA)

Aim: To simulate social engineering attack using Social engineering toolkit (SET).

Learning Outcomes:

After completion of this experiment, student should be able to

1. Understand SEA and its types
2. Simulate phishing attacks using SET.
3. Perform credential harvesting.
4. Describe countermeasures for SEA.

Theory:

Social engineering is an attack vector that relies heavily on human interaction and often involves tricking people into breaking normal security procedures. A social engineer runs what used to be called a "con game." Techniques such as appeal to vanity, appeal to authority and appeal to greed are often used in social engineering attacks. Many social engineering exploits simply rely on people's willingness to be helpful. For example, the attacker might pretend to be a co-worker who has some kind of urgent problem that requires access to additional network resources. SEA can be categorized as

1. Human based SEA refers to a person-to-person interaction to obtain the desired action.
2. Computer based SEA or Technology-based refers to having an electronic interface that attempts to retrieve the desired outcome.
3. Mobile based SEA uses mobile application to extract sensitive information.

Countering SEA:

- Do not provide any information to unknown people
- Do not disclose any confidential information to anyone over the telephone
- Do not type passwords or other confidential information in front of unknown people
- Do not submit information to any insecure Web site
- Do not use same username/password for all accounts
- Verify credentials of persons asking for passwords
- Keep confidential documents locked
- Lock or shut down computers when away from the workstation
- Instruct help desk employees to provide information only after they have gained proper authentication

Procedure:

Task 1: Simulation of phishing attack

1. Start kali linux and login.
2. Go to Application → Exploitation tools → Social Engineering toolkit
3. If you are using it for first time it will ask you to accept terms and condition.. accept it
4. Select social engineering attacks (1)
5. Select website attack vectors (2)

6. Select credential harvester attack method (3)
7. Select web templates (1) or site cloner (2)
8. Give IP address of the machine where you want to collect sensitive information (IP of kali machine).
9. Follow on screen information.
10. For simulation, create one html file and name it as trial.html
11. `<html>`
12. `<head>`
13. `<title>My SE Experiment</title>`
14. `</head>`
- 15.
16. `<body>`
17. `<a href="http://10.0.2.15"[IP Address of Kali Machine]> Click Here to Login </a>`
18. `</body>`
19. `</html>`
20. Open the file in any browser.
21. Enter Username and password
22. UN and PW will be displayed on the SET terminal.

Task 2: Explore other option in SET.

Review question:

1. What is social engineering attack (SEA)? Why SEA are successful?
2. Explain in brief various options available under social engineering attacks in social engineering toolkit.
3. What are the various options under website attack vectors in social engineering toolkit? Explain in brief.
4. Explain credential harvester attack method.
5. NMIMS is an educational organization. The CISO of NMIMS is interested in knowing the susceptibility of the faculty members to phishing attack. To understand the risk, CISO wants to know how many of the faculty members may become victim of the phishing attack. You are an expert social engineer and provide such services. NMIMS has appointed your company for such testing. You are required to draft content for
 - a. Email phishing
 - b. Smishing
 - c. Vishing